

****New Decision****

Copenhagen Municipality receives serious criticism for lack of security measures

Date: 07-05-2024

****Decision****

Public Authorities

Serious Criticism

Reported breach of personal data security

Report of breach of personal data security

Children

Sensitive Information

Unauthorized Access

The Data Protection Agency has expressed serious criticism in a case where approximately 37,500 employees of Copenhagen Municipality unlawfully gained access to information about up to 3.7 million individuals – including sensitive information about children.

Journal number: 2024-442-4149.

****Summary****

In connection with the relocation of files containing a large amount of data (disk swap), a human error resulted in overly broad user access to the drive where the data was stored. This led to approximately 37,500 employees in the municipality unlawfully gaining access to information about up to 3.7 million individuals. The data related to a so-called SAS installation (format for management information, etc.), and only four SAS data warehouse developers were supposed to have access to the data. For the majority of those affected, this included names and address information, but the files also contained information about well-being, language assessments, and information about dental and health care concerning children.

The broad access existed for nearly two months until Copenhagen Municipality discovered the error during a security routine scan of the municipality's open drives. Access was then closed, and the incident was reported to the Data Protection Agency as a breach of personal data security.

The municipality noted in connection with the case that it was assessed that there was a very low probability that an ordinary IT user would encounter the drive, as it required special conditions to find it. Network registration was thus turned off on individual PCs, which meant that employees could not find the drive through ordinary searches on their PCs. This also meant that the URL had to be known, or that there had to be active scanning for the drive. The municipality's investigations showed that no scanning tool had been used to search for open drives during the period of the breach. An examination of the administrative log further showed only accesses for individuals with a work-related need. However, the municipality's logs of all administrative IT users' potential access to the drive did not go back far enough in time for the municipality to definitively conclude that no other employees than those with a work-related need had accessed the information during the period.

The municipality also stated that the majority of SAS files were not immediately readable for those who had unlawfully gained access to them, and that it required the data to be processed in a SAS program first.

****Serious Criticism of Lack of Security Measures****

After a comprehensive assessment of the circumstances of the case, including the time that has passed since the incident, the Data Protection Agency found grounds to express serious criticism that Copenhagen Municipality's processing of personal data had not been carried out in accordance with Article 32, paragraph 1, of the General Data Protection Regulation regarding processing security. The Data Protection Agency thus found that the municipality had not taken appropriate organizational and technical measures to ensure a level of security appropriate to the risks associated with the authority's processing of personal data.

In this regard, the Data Protection Agency emphasized that the municipality had not ensured that only

employees with a work-related need had access to the drive, that there was a setup where a single employee's error could result in a breach affecting 3.7 million individuals, and that it had not been tested immediately after the relocation of the information whether the rights to the drive were correct, which would have immediately revealed the error, as all administrative employees had gained access to it.

The Data Protection Agency generally holds the view that when developing new applications or relocating file drives, it should initially be assessed whether it is necessary to move and store the information in personally identifiable form. If it is necessary for the purpose of processing, a possible security measure could be that the data controller ensures that the information is encrypted so that only an authorized person can read and unlock the information. A proprietary data format (such as a SAS format) cannot be equated with encryption, as there are often viewers or plugins that make it relatively easy to read the relevant file formats.

In all development and maintenance tasks, it is also essential that as part of the change process, requirements are set for those authorized by the data controller to verify that the intended access control, monitoring, and logging work before the change is released for operation.

The Data Protection Agency also noted in the decision that the municipality conducted periodic (quarterly) network scans for shared drives with correct rights, and that the municipality stated it would implement a number of measures to prevent a similar situation from occurring again. However, the Data Protection Agency simultaneously notes that Copenhagen Municipality has subsequently reported several breaches of personal data security, consisting of employees... has gained access to personal data that they do not have a work-related need to access, and that the supervision therefore assumes that there is a continuous focus within the City of Copenhagen to ensure that appropriate security measures are implemented to reduce the risk of such breaches and to ensure that breaches are detected quickly.

Decision

The Data Protection Agency hereby returns to the case where the City of Copenhagen reported a breach of personal data security to the Data Protection Agency on June 17, 2021. The report has the following reference number: ab0615a02eb16368f8f79143b90e83daae7ac961.

1. Decision

After a comprehensive assessment of the circumstances of the case, including the time that has passed since the incident, the Data Protection Agency finds grounds to express serious criticism that the City of Copenhagen's processing of personal data has not been carried out in accordance with the rules in the General Data Protection Regulation [1] Article 32, paragraph 1. Below follows a detailed review of the case and a justification for the Data Protection Agency's decision.

2. Case Presentation

The City of Copenhagen reported a breach of personal data security to the Data Protection Agency on June 17, 2021. The Data Protection Agency received a follow-up on the report on July 10, 2021. By letter dated July 30, 2021, the Data Protection Agency requested further information regarding the case. The City of Copenhagen subsequently provided a statement on August 20, 2021 (dated August 13, 2021).

It appears from the submitted material that during a routine scan on June 15, 2021, of the City of Copenhagen's open file drives, it was found that there was access to a normally closed drive containing data, including personal data, related to a SAS installation [2]. Due to the error, it was possible for employees to search for and open the relevant site. Access was closed immediately after the error was discovered.

Furthermore, investigations have shown that the breach was due to human error, where an employee with administrator access mistakenly granted too broad access to the drive. It is assumed that the error occurred in connection with data being moved to a larger disk on April 17, 2021.

The following is stated about the affected information:

"The total number of individuals affected by the incident is max. 3,750,000.

On the affected E-drive, there are, among other things, the following information:

P-data Address information max 3,750,000 CPR numbers.

Information about students, including withdrawn students approx. 504,000 CPR numbers.

Information about students' parents approx. 480,000 CPR numbers.

Information about children in daycare, including withdrawn children approx. 303,000 CPR numbers.

Information about the children's parents approx. 120,000 CPR numbers.

Basic information about staff approx. 126,000 CPR numbers.

Note – the above are only unique CPR numbers within each type of information – i.e., the number of CPR numbers cannot be added together. For example, the 504,000 students' CPR numbers are also included in the P-data Address information dataset."

It further appears that for the majority of the affected registered individuals, it concerns name and address information, but in addition, the files also contain information about institutions/schools, family relations for the group of children/parents in the municipality, as well as in some cases information about well-being, language assessment, and information about dental and health care.

The City of Copenhagen has stated that access was too broad during the period from April 19, 2021, to June 15, 2021, and that there was no access for individuals outside the City of Copenhagen. The drive was open to all administrative IT users in the municipality during this period. At the time of the breach's discovery, there were approximately 37,500 administrative IT users in the City of Copenhagen. Access should have been limited to a user group (AD security group) in the Children and Youth Administration. The user group provides access to a total of four SAS Data Warehouse developers at Digitalization and Data in the Children and Youth Administration.

When the breach was discovered, Corporate IT searched for traces in the administrative log, which goes back 35 days. The search only showed accesses from specific and identified individuals with an authorized work-related need to access the server and the drive. However, the municipality's logs of all administrative IT users' potential access to the drive do not go back far enough in time for the municipality to definitively conclude that no other employees than those with a work-related need accessed the server during the period.

The City of Copenhagen has stated that the likelihood of an ordinary administrative IT user in the municipality encountering the drive is very low, as it would require special conditions for an ordinary user to find the drive. In this context, the municipality has stated that network registration is turned off on individual PCs in the municipality. It cannot be activated by an ordinary IT user without special accesses or rights. This means that employees cannot find the server through ordinary searches on the PC. It also means that the URL must be known, or there must be active scanning for the drive. Security in Corporate IT periodically scans for open drives, as this is what an external attacker would do, and in this way, the broad access was identified. The URL appears in the system's documentation, but it requires an intention to find it and copy it into a file explorer. The City of Copenhagen has therefore assessed that an ordinary IT user in the municipality did not have the insight to find the open server.

Copenhagen Municipality has also demonstrated that no scanning tool was used to search for open drives during the period of broad access. Furthermore, Copenhagen Municipality has stated that a very small subset of the total data volume was available in clear text (0.2%). The remaining portion of the data volume (99.8%) consists of SAS files[3], which require data to be processed in a SAS program, and this data has therefore not been readable by a random administrative user in Copenhagen Municipality. Copenhagen Municipality has indicated that the total data volume, of which 0.2% was available in clear text, amounted to 1,827 gigabytes as of August 10, 2021. In this context, Copenhagen Municipality has noted that the data volume changes daily in connection with ongoing data runs/updates. The 0.2% of the total data volume consisted of 8,424 files distributed across the file types xls,xlsx,xlsb, and txt. The content of these files originates from a number of administrative systems and specialized systems and largely consists of school and institutional data, and to a lesser extent, information from the municipal children's dental care and health care specialized systems in

Copenhagen Municipality. In addition, Copenhagen Municipality has stated that for the data containing personal information, it is the case that the majority will contain information about children. However, part of the 0.2% also includes various types of aggregated report data and support data, for example, organizational data used for management information. Copenhagen Municipality has stated that data could be accessed via another SAS installation. In this context, the municipality has noted that the municipality's overall network installation is monitored with the cybersecurity product "Darktrace," which would have detected and alerted if there had been attempts to retrieve these SAS files. The following is stated about Copenhagen Municipality's measures before the incident:

"Access management to the solution is conducted through AD groups. Employees with a work-related need can thus be granted access to areas with personal data at CPR number level through membership in one or more so-called AD security groups. Periodic (quarterly) network scans are conducted for shared drives with correct rights. Real-time network monitoring is conducted with associated incident management, which detects, for example, the movement of large data volumes and unusual user behavior. User instructions for data handling are available in the form of internal guidance, and training of employees is conducted. Among more standard technical measures, the following can be mentioned: Perimeter security in the form of firewalls and VPN with two-factor authentication. Network isolation of servers, both with internal firewall and micro-segmentation. Access restriction on servers in the form of access control lists. Central server log collection in a SIEM system."

The following is stated about Copenhagen Municipality's measures after the incident:

"Moving forward, Copenhagen Municipality has, among other things, initiated the following initiatives to prevent a similar situation from occurring again: Ensured that changes to server rights are logged to SIEM (SIEM stands for Security Information & Event Management and is a collective term for a system that can collect logs from many different systems and is used to set up automated log follow-up), so that precise changes can be tracked and do not require interviews with employees. Instructions are issued to all employees in the municipality's Corporate IT that rights on shares or drives must not be changed without an order from the system owner. A common administrative procedure is being developed, which describes rules and responsibilities in connection with the creation of shares on servers. In extension of the procedure, the Children and Youth Administration also instructs employees and external consultants that all changes in rights on shares and drives must be created as orders in ServiceNow. The Children and Youth Administration revisits the risk assessment for the processing of personal data on the server."

3. Justification for the Data Protection Authority's decision

The Data Protection Authority, based on what Copenhagen Municipality has stated, concludes that due to human error, an employee in Copenhagen Municipality with administrator access granted overly broad access to a drive in connection with a disk swap on April 17, 2021, whereby all approximately 37,500 employees in the municipality unjustifiably gained access to information about up to 3.7 million registered individuals, including information about well-being, language assessment, and information about dental and health care concerning children. The Data Protection Authority concludes that unauthorized access to personal data has occurred, and therefore the authority finds that there has been a breach of personal data security, cf. Article 4, no. 12 of the General Data Protection Regulation.

3.1. Article 32 of the General Data Protection Regulation

It follows from Article 32, paragraph 1 of the General Data Protection Regulation that the data controller must take appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data. Thus, the data controller has an obligation to identify the risks that the data controller's

****Processing constitutes a risk for the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects against these risks. As examples of relevant measures, the provision highlights, among other things, pseudonymization and encryption, the ability to ensure ongoing confidentiality, and procedures for regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure processing security, cf. Article**

32, paragraph 1, letters a, b, and d.**

It follows further from Article 32, paragraph 2, that in assessing what level of security is appropriate, particular consideration shall be given to the risks posed by the processing, especially in the event of accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.

It is the opinion of the Data Protection Agency that the requirement under Article 32 for appropriate security will normally imply that in systems with a large number of confidential information about a large number of users, higher demands must be placed on the data controller's diligence in ensuring that, among other things, unauthorized access to personal data does not occur. The City of Copenhagen's handling of personal data concerning up to 3.7 million individuals, including confidential and sensitive information, therefore places significant demands on the municipality's diligence in ensuring, among other things, that unauthorized access to the information does not occur. This applies, among other things, in a processing activity where such personal data is stored on a drive, and where it must therefore take place in a manner that ensures that only employees with a work-related need have access to the information.

Furthermore, it is the opinion of the Data Protection Agency that the requirement for appropriate security will normally entail that the data controller, upon a subsequent change/movement of data concerning a large number of data subjects, and where many employees can gain unauthorized access to the information due to a single human error, immediately following such a change/movement tests whether access rights are limited to the relevant users and to the personal data that are necessary and relevant for the respective users' work-related needs, or if there is broader access, that the data controller encrypts the personal data. Thus, it is the opinion of the Data Protection Agency that the data controller, during disk swapping, must implement measures to verify that the rights on folders and files on the new disk are set identically to the rights on the previous disk.

Based on the above and after a comprehensive assessment of the circumstances of the case, including the time that has elapsed since the incident, the Data Protection Agency finds grounds to express serious criticism of the City of Copenhagen's processing of personal data – by failing to ensure that only employees with a work-related need had access to the drive, by having a setup where a single employee's mistake could result in a breach affecting 3.7 million individuals, and by not immediately testing after the transfer of the information whether the rights to the drive were correct, which would have immediately revealed the error, as all administrative employees had access – has not occurred in accordance with the General Data Protection Regulation's Article 32, paragraph 1. As a result of the above, it is found that appropriate organizational and technical measures have not been taken to ensure a security level that is commensurate with the risks associated with the authority's processing of personal data.

Furthermore, the Data Protection Agency does not find that the circumstance that most of the data (99.8%) required a SAS installation to be readable can lead to a different assessment, as it is relatively easy to download a SAS installation from the internet and thereby exploit the data. The Data Protection Agency has noted that, according to the information provided, periodic (quarterly) network scans are conducted for shared drives with correct rights, and that it was precisely such a scan that caused the City of Copenhagen to discover the breach itself, and that the duration of this was limited to about 2 months. The Data Protection Agency has also noted that the City of Copenhagen would implement a number of measures to prevent a similar situation from occurring again. However, the Data Protection Agency simultaneously observes that the City of Copenhagen has subsequently reported several breaches of personal data security, consisting of employees having gained access to personal data that they do not have a work-related need to access, and that the agency therefore assumes that there continues to be a focus at the City of Copenhagen on ensuring that appropriate security measures are implemented to reduce the risk of such breaches and to ensure that potential breaches are detected quickly.

**[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the

protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] A SAS installation is a special format for management information and databases.

[3] SAS files are also readable for those who have installed the correct software, which is available online, i.e., if one has downloaded the correct "viewer."**